

Vlumeaware

A phishing-simulation and security-awareness platform for Nigerian SME and mid-market clients — measure who clicks, then route them straight into the training that fixes it.

OWNER	SURFACES	DATA MODEL	CONTENT PACK
Vlumetech it@vlumetech.com.ng	3 + 2 consoles + portals	23 tables · 11 migrations	10 ISO 27001:2022 topics

01 Executive summary

What Vlumeaware is, and why it exists.

Vlumeaware runs authorized phishing simulations against a client's own employees, measures who opens, clicks, reports, and submits credentials, and then **auto-routes anyone who falls for a lure into the exact training module that addresses that attack** — closing the loop from exposure to remediation without a human in the middle.

It is a paid add-on to Vlumetech's security-awareness curriculum and VAPT services, not a standalone tool. It differentiates from KnowBe4, Proofpoint, Cofense and SoSafe on three axes: **NDPA/NDPR compliance** baked into the workflow, **Nigerian business context** (invoice- and mandate-fraud lures, local payroll cycles, CBN/FIRS notice formats), and a **closed training feedback loop** grounded in an ISO 27001:2022 content pack.

The platform is multi-tenant from the ground up: every client's data is isolated at the database-query layer, not merely in application logic. Two gates protect against misuse

— a signed-authorization consent gate blocks any simulation for an unapproved client, and a **domain-ownership gate** ensures a client can only ever phish addresses on a domain it has proven it owns. Clients self-serve onto a 7-day trial; Vlumetech staff approve them into standing, licensed accounts.



The measurable unit is a **send**

— one tracked email to one employee. Every event (open, click, report, credential submission, quiz pass) writes back to that row, which is what makes recipient-level reporting and per-person risk scoring possible.

02 Problem & opportunity

Why a locally-grounded simulator, and why now.

Phishing is the dominant initial-access vector for Nigerian SMEs, and the lures that land are local: vendor bank-mandate changes timed to the monthly invoice run, fake CBN/FIRS re-verification notices, payroll-account confirmations. Global awareness platforms train against US-centric templates and treat compliance as an afterthought — an awkward fit for an organisation answerable to the NDPA.

Compliance-first — consent gate blocks unauthorized sends

Domain-bound — can only phish addresses you own

Local context — invoice, payroll, CBN/FIRS lures

Closed loop — a click auto-assigns the fixing module

ISO-aligned — ten Annex A awareness topics ready to run

The opportunity is to be the awareness platform a Nigerian mid-market CISO can put in front of their board and their regulator with equal confidence.

03 Goals & non-goals

Deliberately narrow, defensively built.

Goals

- Provably isolate every client's data at the query layer.
- Make it impossible to simulate without signed authorization *or* to email anyone off a verified domain.
- Auto-route failures into targeted training; measure completion with certificates.
- Give Vlumetech staff a curated, reusable catalogue of scenarios, videos and quizzes.
- Let clients self-serve onto a trial and staff approve them into licensed accounts.

Non-goals (v1)

- Not a SIEM or email gateway — it simulates and measures, it does not filter real mail.
- No real-time SOC / incident-response integration.
- No storage of what an employee types on a simulated login page (metadata only).
- Not multi-language yet (English only in v1).

Scope evolved during build

Several items were promoted to first-class features on request: self-serve signup, a content-authoring stack (template catalogue, manual composer, quizzes, shared libraries), and **domain-ownership verification**. All are documented below.

04 Roles & surfaces

Three roles, three consoles, two sign-in portals.

ROLE	SCOPE	CONSOLE	PORTAL
vlumetech_superuseradmin	All tenants (cross-client)	Staff console — clients, scenario catalogue, approvals, shared video & quiz libraries, audit	/admin
client_admin	Their own tenant	Full client console — campaigns, scenarios, content, domains, employees, reporting	/login
client_viewer	Their own tenant (read)	Read-only reporting, risk, certificates	/login

Vlumetech staff and clients sign in at **separate URLs**; each portal accepts only its own roles and refuses a wrong-role sign-in without storing a session. The client console groups navigation into **Phishing, Training, People and Reporting**; the staff console is a flat set of platform tools. The UI is a light, KnowBe4-style theme with a shared emerald brand accent.

05 The core loop

From an approved scenario to a measured, remediated employee.

1. **Author or clone a scenario.** A client clones one from the global catalogue (or Claude drafts one), edits it, and submits it for review.
2. **Vlumetech approves.** Only an approved scenario can be attached to a live campaign.
3. **Launch a campaign.** One *send* is materialised per employee per scenario — but only for employees on a **verified domain**.
4. **Track.** Opens (pixel), clicks (redirect to a simulated landing page), credential submissions and report-a-phish actions all write back to the send.
5. **Teach.** A click lands the employee on a teachable-moment page that names the scenario's red flags and plays the assigned awareness video.
6. **Assess.** A short quiz follows; a pass marks the employee's training complete and issues a certificate.

7. **Remediate.** Repeat clickers are surfaced on the risk board and can be auto-enrolled into a remediation module.

06 Feature specification

Each block lists its acceptance criteria.

Employee onboarding & domain verification NEW

A client proves it owns a domain via a DNS TXT record before it can onboard anyone on it — so no one outside the organisation is ever phished.

- ✓ Add multiple domains; each gets a unique token and a TXT record to publish at `_vlumeaware.<domain>`.
- ✓ **Verify** performs a live DNS lookup and flips the domain to *verified*.
- ✓ Adding employees (single or CSV) rejects any address not on a verified domain, with a clear reason.
- ✓ Campaign launch filters recipients to verified domains — a second guard, so a stale row can't leak out.
- ✓ Single-employee add and bulk-CSV upload; existing rows update rather than duplicate; seat limits enforced.

Scenario catalogue & approvals STAFF + CLIENT

A global library of phishing scenarios that staff author and clients clone.

- ✓ Staff add / edit / delete catalogue scenarios (subject, spoofed sender, HTML body, red flags, difficulty).
- ✓ Clients clone a catalogue scenario or generate one with Claude, then edit it.
- ✓ Every client scenario is *unapproved* until Vlumetech reviews it; the approvals queue shows a cross-tenant list with an email preview and approve / reject.
- ✓ Placeholders `{{EMPLOYEE_NAME}}` and `{{TRACKING_URL}}` are substituted at send time.

Campaigns & simulation CLIENT

The measurement engine.

- ✓ Create a campaign, attach one or more approved scenarios, select employees, launch now or schedule.
- ✓ A preflight checklist gates launch (employees present, approved scenario attached, consent on file).
- ✓ Sends are queued through Redis/BullMQ; a kill switch halts an active campaign.
- ✓ Tracking endpoints record open, click, credential submission and report; report only credits a catch when it precedes a click.
- ✓ Emails send via SES when configured; otherwise a log mailer records them for safe testing.

Awareness training & shared video library STAFF + CLIENT

Video modules a client uploads or links, plus a global library staff curate.

- ✓ Add a module by hosted link or by uploading a video file (stored in Supabase Storage, playable https URL).
- ✓ **Preview** plays any module — upload or link — before it goes out.
- ✓ Clients clone modules from the shared Vlumetech library into their own.
- ✓ The teachable-moment page serves the assigned module to the employee who clicked.

Quizzes & shared quiz library NEW

Knowledge checks that gate training completion, with a reusable global library.

- ✓ Staff publish shared quizzes; clients clone one onto a training module or author their own.
- ✓ Questions via a form, bulk JSON, or CSV import; correct answers and explanations per question.
- ✓ Scored server-side; a pass at the configured mark marks training complete and issues a certificate.
- ✓ Per-quiz results show each employee's score and pass/fail.

Reporting, risk & certificates

CLIENT + STAFF

- ✓ Campaign reporting: open, click, report and submission rates.
- ✓ Per-employee risk scoring; a repeat-clicker list with one-click auto-enrol into a remediation module.
- ✓ Certificates issued on quiz pass; a Reported view lists caught simulations.
- ✓ Staff cross-client overview and an append-only audit log.

Multi-tenant, trial & licensing

PLATFORM

- ✓ Self-serve signup creates a 7-day trial tenant capped at 20 seats; staff approve into a licensed tier with a seat limit.
- ✓ A writable-tenant guard blocks creation and sending for unapproved / lapsed / suspended tenants.
- ✓ Deliverability settings (sending domain, allowlist) recorded per tenant.

07 ISO 27001:2022 content pack

Ten ready-to-run awareness topics, each a video + quiz + phishing simulation.

The pack maps to Annex A (2022) controls so it can be dropped into a statement of applicability. The ten phishing simulations are loaded into the global catalogue and the ten quizzes into the shared quiz library; video scripts are authored and awaiting production files.

#	TOPIC	ANNEX A	DELIVERABLES
1	Phishing & social engineering	A.6.3, A.5.7	Video · quiz · simulation
2	Passwords & MFA	A.5.17, A.8.5	Video · quiz · simulation
3	Clear desk / acceptable use	A.7.7, A.5.10	Video · quiz · simulation
4	Information classification	A.5.12–5.14	Video · quiz · simulation
5	Secure remote & mobile working	A.6.7, A.8.1	Video · quiz · simulation
6	Physical security & tailgating	A.7.1–7.6	Video · quiz · simulation
7	Security incident reporting	A.5.24–5.26	Video · quiz · simulation
8	Malware & ransomware	A.8.7, A.8.19	Video · quiz · simulation
9	Removable media & data transfer	A.7.10, A.8.12	Video · quiz · simulation
10	Personal data & privacy (PII)	A.5.34, A.8.11	Video · quiz · simulation

08 Technical architecture

A monorepo, deployed entirely on free tiers.

API NestJS (Node 22) · Prisma 6

Web Next.js 16 · React 19 · Tailwind

DB PostgreSQL (Supabase)

Queue BullMQ · Redis

Storage Supabase Storage

AI Claude (scenario drafting)

Mail AWS SES / log mailer

- **Web** (Next.js) on Vercel — the two consoles and the public teachable-moment / simulated-login pages.
- **API + worker** (NestJS, one Docker image) on Render — the API serves requests; the worker drains the send and scheduler queues.
- **Database** on Supabase Postgres (session pooler), with a tenant-guard Prisma extension enforcing isolation and RLS enabled on every table.
- **Redis** (Render Key Value) backs BullMQ for send scheduling and send-window pacing.

- **Object storage** in a public Supabase bucket for awareness videos, returning playable https URLs.

Known free-tier constraints

Render's free web service cold-starts after idle (~50 s first request) and has an ephemeral disk; video storage was moved to Supabase for durability. Removing cold-starts and adding persistent Redis + backups is on the roadmap.

09 **Data model**

23 tables across 11 migrations. Tenant-scoped tables carry `tenant_id` and are unreachable without a tenant in context.

DOMAIN	TABLES
Tenancy & identity	<code>tenants</code> , <code>tenant_users</code> , <code>users</code>
People & domains	<code>employees</code> , <code>verified_domains</code>
Scenarios & templates	<code>scenarios</code> , <code>phishing_templates</code>
Campaigns & sends	<code>campaigns</code> , <code>campaign_scenarios</code> , <code>sends</code>
Tracking	<code>reports</code> , <code>credential_submissions</code> , <code>phish_reports</code>
Training	<code>training_modules</code> , <code>shared_training_modules</code> , <code>training_routing_rules</code> , <code>training_assignments</code>
Quizzes	<code>quizzes</code> , <code>quiz_questions</code> , <code>quiz_attempts</code> , <code>shared_quizzes</code>
Outcomes & audit	<code>certificates</code> , <code>audit_log</code>

Bold isolation rule: a build-time test fails if any model gains a `tenant_id`

without being registered in the tenant guard — isolation cannot silently regress.

10 API surface

Selected endpoints. Tenant-scoped routes carry `/tenants/:tenantId`; the interceptor binds scope from the verified JWT, not the URL.

METHOD	ROUTE	PURPOSE
POST	<code>/tenants/:t/domains</code>	Add a domain to verify
POST	<code>/tenants/:t/domains/:id/verify</code>	Live DNS TXT check
POST	<code>/tenants/:t/employees</code>	Add employees (domain-guarded)
GET	<code>/phishing-templates</code>	Global scenario catalogue
POST	<code>/phishing-templates</code>	Staff: add a catalogue scenario
GET	<code>/admin/scenarios/pending</code>	Cross-tenant approvals queue
POST	<code>/admin/scenarios/:id/approve</code>	Approve a client scenario
GET	<code>/shared-quizzes</code>	Global quiz library
POST	<code>/tenants/:t/quizzes/from-shared/:id</code>	Clone a shared quiz onto a module
POST	<code>/tenants/:t/campaigns/:id/launch</code>	Materialise & queue sends
GET	<code>/track/click/:token</code>	Public: record click → teachable moment
POST	<code>/track/quiz/:token</code>	Public: submit quiz, score, certify

11 Security & compliance

Isolation and consent are structural, not conventions.

- **Query-layer tenant isolation.** A Prisma extension narrows every read and write to the tenant in async context; a superadmin-only `runAsSystem` escape hatch is the sole cross-tenant path, and it is audited.
- **Consent gate.** No simulation runs for a tenant without a signed authorization agreement and an approved status.
- **Domain-ownership gate.** Employees can only be onboarded and emailed on DNS-verified domains — enforced at both add and send.
- **Row-level security** is enabled on every table; the application connects as a role that bypasses RLS, giving defence in depth against a direct-DB mistake.
- **Credential capture is metadata-only** — the simulated login records that a submission happened, never the plaintext an employee typed.
- **Auth** is JWT with per-portal role checks and rate-limited sign-in; separate staff and client entry points.

Open security actions

Rotate the database password exposed during setup and replace the seeded demo passwords before onboarding real clients. Move uploaded-video storage to a private bucket with signed URLs when reputational/PII sensitivity increases.

12 Non-functional requirements

Reliability & performance

- Sends are pre-materialised before any job runs, so reporting has a complete denominator and the kill switch has something to halt.
- Send-window pacing spreads a campaign over a configurable interval.
- Cold-start and ephemeral-disk limits of the free tier are documented and slated for removal.

Deliverability & testability

- The log mailer lets the full click→training→quiz path be tested without sending real email.
- SPF/DKIM/DMARC posture for the sending domain is a planned pre-flight check.
- A dedicated sending identity keeps simulation traffic off the corporate domain's reputation.

13 Roadmap

The agreed next four, in build order.

#	INITIATIVE	WHY IT'S NEXT
1	Deliverability + real email (SES)	Nothing is fully testable until simulations actually land; pairs with an SPF/DKIM/DMARC checker.
2	Reliability / off free-tier	Persistent Redis, no cold-starts, DB backups, error monitoring, private video bucket — needed the moment real mail sends on a schedule.
3	Campaign scheduling	Send windows, randomized/drip times, timezones, recurring awareness programmes.
4	Reporting & exports	Executive dashboard, CSV/PDF export, per-department trends, branded certificate PDFs.

Further candidates: admin MFA and session policy, employee consent/notification and manager nudges, a simulated-login landing-page builder, a suppression/never-send list, and localization (e.g. Hausa) for a Nigerian workforce.

14 **Build & deploy status**

Where each capability stands today.

CAPABILITY	STATUS
Core simulation loop, campaigns, tracking, training routing	● Live
Multi-tenant isolation, trial & licensing, approvals	● Live
Light-theme UI, grouped nav, video preview	● Live
ISO 27001 phishing scenarios & quizzes (data)	● Loaded in DB
Domain verification, shared quiz library, staff scenario authoring, single-employee add, Supabase Storage	● Built — awaiting deploy
ISO 27001 awareness videos	● Scripted — awaiting production files
SES real email, reliability hardening, scheduling, exports	● Roadmap

● Live on the free-tier deployment

● In the codebase, needs push + redeploy

●

Planned